

Penetration Testing - Lab 2: No Credentials

Course: CSEC 471 - Penetration Testing

Name: Naor Golan

Date: 2/3

Introduction

This report documents the **network scanning and enumeration phase** of a penetration test in an **Active Directory (AD) environment** using **no credentials**. The objectives include:

- Identifying **live hosts** and their **open services**.
- Discovering **potential vulnerabilities**.
- Executing **additional reconnaissance tasks** beyond the initial network scan.
- Analyzing security risks and providing **mitigation strategies**.

Table of Contents

<u>Ping Scan</u>	<u>1</u>
<u>Quick Scan.....</u>	<u>4</u>
<u>Full TCP Scan.....</u>	<u>4</u>
<u>UDP Scan</u>	<u>4</u>
<u>SMB Vulnerability Scan</u>	<u>4</u>
<u>SMB Share Enumeration (CrackMapExec)</u>	<u>4</u>
<u>Additional Task Execution: Zone Transfer Attempt.....</u>	<u>4</u>
<u>Additional Task Execution: Enumerating SMB Users</u>	<u>4</u>
<u>Final Task Execution: Enumerate Guest SMB Access.....</u>	<u>4</u>

Network Scanning Results

2.a Ping Scan (Host Discovery)

Command Used:

`nmap -sP 192.168.56.0/24`

Findings:

- Discovered **7 active hosts** on the network.
- Collected **MAC addresses** of the hosts, indicating they are virtualized environments (VMware).

```
(kali@kali)-[~]
$ nmap -sP 192.168.56.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-01-31 08:21 PST
Nmap scan report for 192.168.56.4
Host is up (0.11s latency).
MAC Address: 00:50:56:B0:63:F9 (VMware)
Nmap scan report for 192.168.56.10
Host is up (0.11s latency).
MAC Address: 00:50:56:B0:5B:58 (VMware)
Nmap scan report for 192.168.56.11
Host is up (0.11s latency).
MAC Address: 00:50:56:B0:29:1E (VMware)
Nmap scan report for 192.168.56.12
Host is up (0.00028s latency).
MAC Address: 00:50:56:B0:CA:53 (VMware)
Nmap scan report for 192.168.56.22
Host is up (0.00094s latency).
MAC Address: 00:50:56:B0:4E:59 (VMware)
Nmap scan report for 192.168.56.23
Host is up (0.00089s latency).
MAC Address: 00:50:56:B0:73:D5 (VMware)
Nmap scan report for 192.168.56.5
Host is up.
Nmap done: 256 IP addresses (7 hosts up) scanned in 3.73 seconds
```

Potential Risks:

- Allows attackers to **map active hosts** and identify potential targets for further enumeration.

Mitigation:

- Disable **ICMP echo requests** on non-essential devices.
- Implement **network segmentation** to restrict host discovery.

2.b Quick Scan (Top 50 Ports)

Command Used:

```
nmap -Pn -sV --top-ports 50 --open 192.168.56.0/24
```

Findings:

- Identified **open ports (53, 80, 135, 139, 445, 3389)** across multiple hosts.
- Detected **Windows-based servers running SMB, RDP, and DNS services.**
- Windows RPC (135) and Terminal Services (3389) were found on multiple systems, suggesting **remote management capabilities.**

```
(kali㉿kali)-[~]
└─$ nmap -Pn -sV --top-ports 50 --open 192.168.56.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-01-31 08:35 PST
Nmap scan report for 192.168.56.10
Host is up (0.0011s latency).
Not shown: 44 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
53/tcp    open  domain         Simple DNS Plus
80/tcp    open  http           Microsoft IIS httpd 10.0
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server  Microsoft Terminal Services
MAC Address: 00:50:56:B0:5B:58 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.56.11
Host is up (0.0019s latency).
Not shown: 45 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
53/tcp    open  domain         Simple DNS Plus
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server  Microsoft Terminal Services
MAC Address: 00:50:56:B0:29:1E (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.56.12
Host is up (0.00018s latency).
Not shown: 45 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
53/tcp    open  domain         Simple DNS Plus
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: ESS05)
3389/tcp  open  ms-wbt-server  Microsoft Terminal Services
MAC Address: 00:50:56:B0:CA:53 (VMware)
Service Info: Host: MEEREEN; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Potential Risks:

- Open **SMB (445)** services could be exploited via **SMB relay attacks** or **EternalBlue exploits**.
- Open **RDP (3389)** services could be **brute-forced** or **subjected to credential stuffing attacks**.
- Open **DNS (53)** services may allow **zone transfers** or **DNS poisoning** if misconfigured.

Mitigation:

- Restrict **SMB and RDP access** to internal users only.
- Apply **patches and security updates** for known vulnerabilities.
- Enforce **multi-factor authentication (MFA)** for remote services.

2.c Full TCP Scan

Command Used:

```
nmap -Pn -sT -sC -sV -oN full_tcp_scan.txt 192.168.56.0/24
```

Findings:

- A very slow but methodical scan that found 5 hosts (due to its nature of assuming all targets in the scan are active)

[illegible]

Potential Risks:

- Misconfigured **RPC services** can be used for remote code execution or lateral movement.
- SMB vulnerabilities could allow unauthenticated access or credential theft.

Mitigation:

- Restrict **RPC and SMB services** to authenticated users.
- Regularly **audit and patch** network services for security risks.

2.d UDP Scan

Command Used:

```
nmap -Pn -sU -sC -sV -oN udp_scan.txt 192.168.56.0/24
```

Findings:

- **Found multiple open UDP ports, including:**
 - 53/udp (DNS) Recursive queries enabled.
 - 88/udp (Kerberos) Indicates Active Directory domain authentication.
 - 389/udp (LDAP) Used for AD user authentication and queries.
 - 123/udp (NTP) Network time synchronization service.
 - 137/udp (NetBIOS-NS) Identified hostname: KINGSLANDING.
- **Domain identified:** sevenkingdoms.local.

```
File Actions Edit View Help
(kali@kali)-[~]
$ nmap -Pn -sU -sC -sV -oN udp_scan.txt 192.168.56.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-03 00:01 PST
Stats: 0:06:21 elapsed; 249 hosts completed (6 up), 6 undergoing UDP Scan
UDP Scan Timing: About 54.32% done; ETC: 00:12 (0:05:17 remaining)
Stats: 1:50:12 elapsed; 249 hosts completed (6 up), 6 undergoing Service Scan
Service scan Timing: About 83.82% done; ETC: 02:06 (0:15:37 remaining)
Stats: 1:52:20 elapsed; 249 hosts completed (6 up), 6 undergoing Service Scan
Service scan Timing: About 86.14% done; ETC: 02:06 (0:13:21 remaining)
Stats: 2:02:21 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 98.60% done; ETC: 02:03 (0:00:04 remaining)
Stats: 2:09:21 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 98.68% done; ETC: 02:10 (0:00:09 remaining)
Stats: 2:25:33 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 98.83% done; ETC: 02:26 (0:00:19 remaining)
Stats: 2:34:00 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 98.89% done; ETC: 02:35 (0:00:24 remaining)
Stats: 3:00:13 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 99.05% done; ETC: 03:01 (0:00:36 remaining)
Stats: 3:31:34 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 99.19% done; ETC: 03:33 (0:00:45 remaining)
Nmap scan report for 192.168.56.4
Host is up (0.10s latency).
All 1000 scanned ports on 192.168.56.4 are in ignored states.
Not shown: 1000 open/filtered udp ports (no-response)
MAC Address: 00:50:56:B0:63:F9 (VMware)

Nmap scan report for 192.168.56.10
Host is up (0.00053s latency).
Not shown: 909 closed udp ports (port-unreach)
PORT      STATE      SERVICE      VERSION
53/udp    open       domain       Simple DNS Plus
|_dns-recursion: Recursion appears to be enabled
88/udp    open       kerberos-sec Microsoft Windows Kerberos (server time: 2025-02-03 08:01:48Z)
123/udp   open       ntp          NTP v3
| ntp-info:
|_
137/udp   open       netbios-ns   Microsoft Windows netbios-ns (Domain controller: NORTH)
| nbns-interfaces:
|_ hostname: KINGSLANDING
|_ interfaces:
|_ 192.168.56.10
138/udp   open/filtered netbios-dgm
389/udp   open       ldap        Microsoft Windows Active Directory LDAP (Domain: sevenkingdoms.local0., Site: Default-First-Site-Name)
464/udp   open/filtered kpasswd5
500/udp   open/filtered isakmp
3389/udp   open/filtered ms-wbt-server
4500/udp   open/filtered nat-t-ike
5353/udp   open/filtered zeroconf
5355/udp   open/filtered llmnr
49152/udp open       domain      (generic dns response: SERVFAIL)
| fingerprint-strings:
|_ NBTStat:
|_ CKAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
49153/udp open       domain      (generic dns response: SERVFAIL)
```

Potential Risks:

- Open DNS recursion can lead to DNS amplification attacks and DNS cache poisoning.
- Kerberos vulnerabilities could lead to ticket forgery or credential compromise.
- Open LDAP can leak sensitive AD user details.
- NTP reflection attacks are possible if misconfigured.

Mitigation:

- Disable DNS recursion if not needed or have a backup plan if it is being exploited.
- Restrict LDAP access to authenticated users.
- Ensure Kerberos services are properly secured and patched.
- Limit NTP access to internal hosts only.

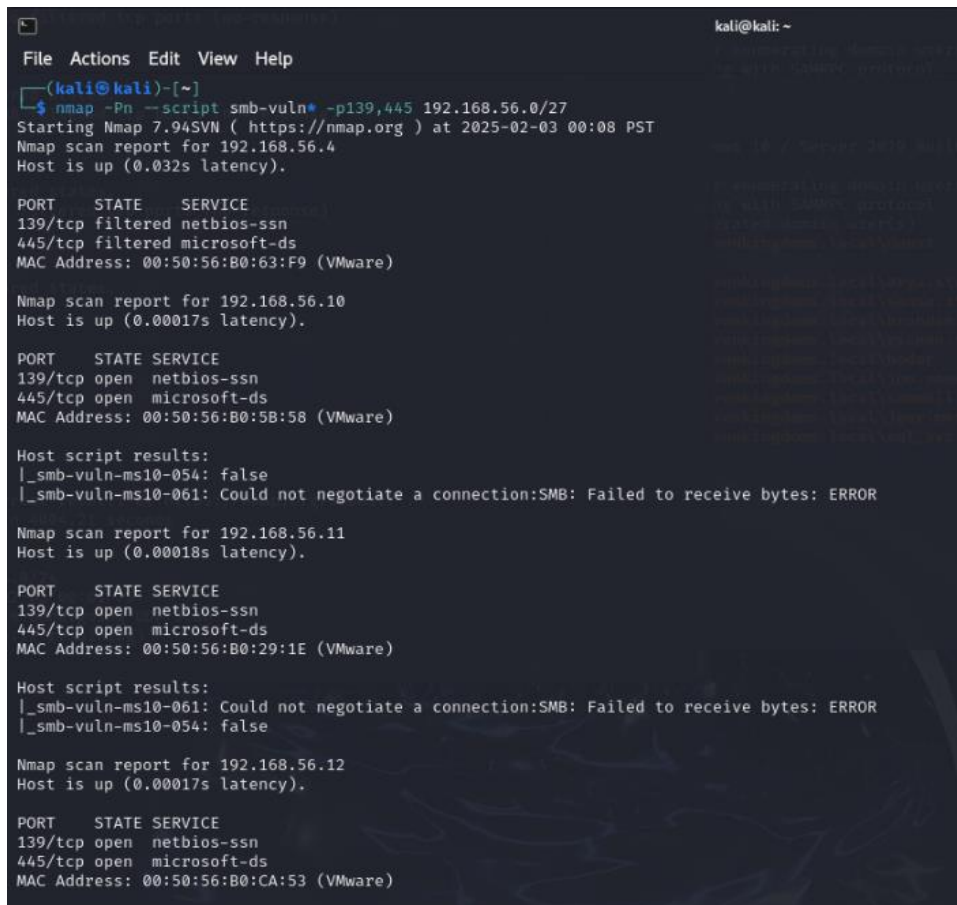
2.e SMB Vulnerability Scan

Command Used:

```
nmap -Pn --script smb-vuln* -p139,445 192.168.56.0/27
```

Findings:

- Discovered **open SMB services**, but some hosts returned **filtered responses**.
- Attempted to check for **SMBv1 vulnerabilities (MS17-010/EternalBlue)**, but results were inconclusive.



```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)~  
$ nmap -Pn --script smb-vuln* -p139,445 192.168.56.0/27  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-03 00:08 PST  
Nmap scan report for 192.168.56.4  
Host is up (0.032s latency).  
  
PORT      STATE SERVICE  
139/tcp    filtered netbios-ssn  
445/tcp    filtered microsoft-ds  
MAC Address: 00:50:56:B0:63:F9 (VMware)  
  
Nmap scan report for 192.168.56.10  
Host is up (0.00017s latency).  
  
PORT      STATE SERVICE  
139/tcp    open  netbios-ssn  
445/tcp    open  microsoft-ds  
MAC Address: 00:50:56:B0:5B:58 (VMware)  
  
Host script results:  
|_smb-vuln-ms10-054: false  
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR  
  
Nmap scan report for 192.168.56.11  
Host is up (0.00018s latency).  
  
PORT      STATE SERVICE  
139/tcp    open  netbios-ssn  
445/tcp    open  microsoft-ds  
MAC Address: 00:50:56:B0:29:1E (VMware)  
  
Host script results:  
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR  
|_smb-vuln-ms10-054: false  
  
Nmap scan report for 192.168.56.12  
Host is up (0.00017s latency).  
  
PORT      STATE SERVICE  
139/tcp    open  netbios-ssn  
445/tcp    open  microsoft-ds  
MAC Address: 00:50:56:B0:CA:53 (VMware)
```

Potential Risks:

- If **SMBv1 is enabled**, the system is vulnerable to **EternalBlue attacks**.
- Open **SMB shares** without authentication could allow **data theft or lateral movement**.

Mitigation:

- Disable **SMBv1** and enforce **SMBv2/SMBv3**.
- Apply **Microsoft security patches** against SMB vulnerabilities.
- Restrict **SMB share permissions** to authenticated users only.

2.f SMB Share Enumeration (CrackMapExec)

Command Used:

```
crackmapexec smb 192.168.56.0/27 -u "" -p "" --shares
```

Findings:

- **Discovered Windows servers with SMB services enabled:**
 - 192.168.56.12 (MEEREEN) - Windows Server 2016
 - 192.168.56.22 (CASTLEBLACK) - Windows 10/Server 2019
 - 192.168.56.23 (BRAAVOS) - Windows Server 2016
 - 192.168.56.10 (KINGSLANDING) - Windows 10/Server 2019
 - 192.168.56.11 (WINTERFELL) - Windows 10/Server 2019
- Share enumeration failed on most hosts due to **STATUS_ACCESS_DENIED**.
- Some hosts returned errors while reading from remote, likely due to network restrictions.

```
(kali@kali)-[~]
$ crackmapexec smb 192.168.56.0/27 -u "" -p "" --shares
SMB 192.168.56.12 445 MEEREEN [*] Windows Server 2016 Standard 14393 x64 (name:MEEREEN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB 192.168.56.22 445 CASTLEBLACK [*] Windows 10 / Server 2019 Build 17763 x64 (name:CASTLEBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB 192.168.56.23 445 BRAAVOS [*] Windows Server 2016 Standard 14393 x64 (name:BRAAVOS) (domain:essos.local) (signing:False) (SMBv1:True)
SMB 192.168.56.10 445 KINGSLANDING [*] Windows 10 / Server 2019 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.12 445 MEEREEN [+] essos.local\
SMB 192.168.56.12 445 MEEREEN [-] Error enumerating shares: STATUS_ACCESS_DENIED
SMB 192.168.56.22 445 CASTLEBLACK [-] north.sevenkingdoms.local\ STATUS_ACCESS_DENIED
SMB 192.168.56.22 445 CASTLEBLACK [-] Error enumerating shares: Error occurs while reading from remote(104)
SMB 192.168.56.23 445 BRAAVOS [-] essos.local\ STATUS_ACCESS_DENIED
SMB 192.168.56.23 445 BRAAVOS [-] Error enumerating shares: Error occurs while reading from remote(104)
SMB 192.168.56.10 445 KINGSLANDING [+] sevenkingdoms.local\
SMB 192.168.56.10 445 KINGSLANDING [-] Error enumerating shares: STATUS_ACCESS_DENIED
SMB 192.168.56.11 445 WINTERFELL [+] north.sevenkingdoms.local\
SMB 192.168.56.11 445 WINTERFELL [-] Error enumerating shares: STATUS_ACCESS_DENIED
```

Potential Risks:

- If any SMB shares were misconfigured with weak permissions, they could be exposed to unauthorized access.
- Attackers could use these findings to attempt credential-based attacks or exploit SMB vulnerabilities.

Mitigation:

- Restrict SMB share access to authenticated users only.
- Ensure SMB signing is enabled across all systems to prevent MITM attacks.
- Regularly audit SMB share configurations to prevent exposure of sensitive files.
- Disable SMBv1 if not already done.

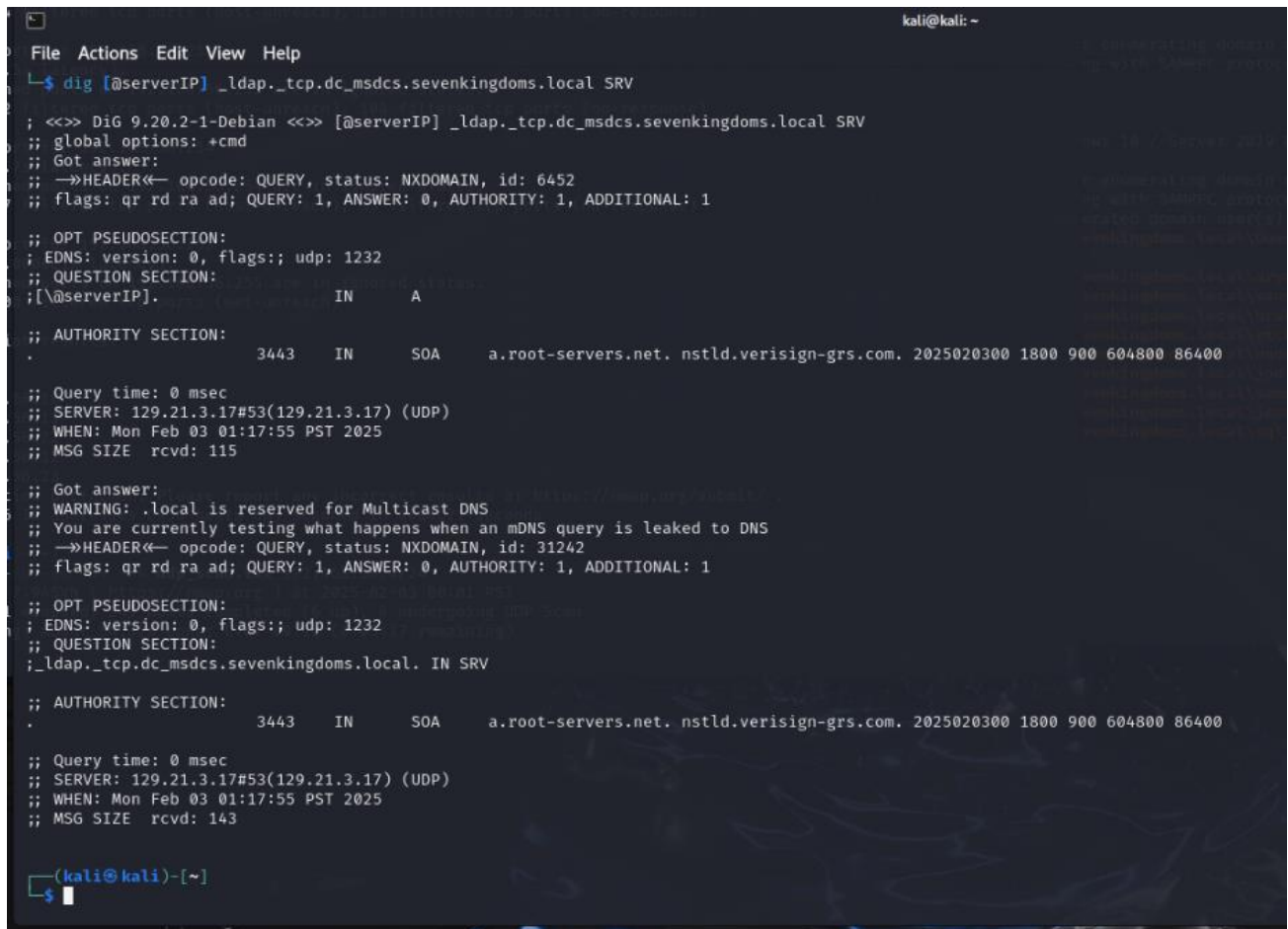
D2. Additional Task Execution: Zone Transfer Attempt

Command Used:

```
dig [@serverIP] _ldap_tcp.dc_msdc.ssevenkingdoms.local SRV
```

Findings:

- The **zone transfer attempt failed**, indicating that the DNS server has **proper restrictions in place**.
- No sensitive DNS records were retrieved.



```
kali@kali: ~
File Actions Edit View Help
└─$ dig [@serverIP] _ldap_tcp.dc_msdc.ssevenkingdoms.local SRV

; <<>> DiG 9.20.2-1-Debian <<>> [@serverIP] _ldap_tcp.dc_msdc.ssevenkingdoms.local SRV
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 6452
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;[@serverIP]. IN A

;; AUTHORITY SECTION:
. 3443 IN SOA a.root-servers.net. nstld.verisign-grs.com. 2025020300 1800 900 604800 86400

;; Query time: 0 msec
;; SERVER: 129.21.3.17#53(129.21.3.17) (UDP)
;; WHEN: Mon Feb 03 01:17:55 PST 2025
;; MSG SIZE rcvd: 115

;; Got answer:
;; WARNING: .local is reserved for Multicast DNS
;; You are currently testing what happens when an mDNS query is leaked to DNS
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 31242
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;_ldap_tcp.dc_msdc.ssevenkingdoms.local. IN SRV

;; AUTHORITY SECTION:
. 3443 IN SOA a.root-servers.net. nstld.verisign-grs.com. 2025020300 1800 900 604800 86400

;; Query time: 0 msec
;; SERVER: 129.21.3.17#53(129.21.3.17) (UDP)
;; WHEN: Mon Feb 03 01:17:55 PST 2025
;; MSG SIZE rcvd: 143

(kali@kali)-[~]
└─$
```

Potential Risks:

- If zone transfers were allowed, attackers could retrieve **internal domain records**, exposing IPs and infrastructure details.

Mitigation:

- Restrict **zone transfers** to authorized DNS servers only.
- Implement **split-horizon DNS** to separate internal and external DNS queries.

D3. Additional Task Execution: Enumerating SMB Users

Command Used:

```
crackmapexec smb 192.168.56.11 -u "" -p "" --users
```

Findings:

- Retrieved a **list of Active Directory users**, including:
 - arya.stark
 - sansa.stark
 - brandon.stark
 - rickon.stark
 - hodor
 - jon.snow
 - samwell.tarly (Password: Heartsbane)
 - jeor.mormont
 - sql_svc
- The presence of a **hardcoded password** for samwell.tarly is a critical security risk.

```
(kali@kali)-[~]
└─$ crackmapexec smb 192.168.56.11 --users
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [-] Error enumerating domain users using dc ip 192.168.56.11: NTLM needs domain\username and a password
SMB 192.168.56.11 445 WINTERFELL [*] Trying with SAMRPC protocol
SMB 192.168.56.11 445 WINTERFELL [*] Enumerated domain user(s)
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Guest Built-in account for guest access to the computer/domain
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\arya.stark Arya Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\sansa.stark Sansa Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\brandon.stark Brandon Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\rickon.stark Rickon Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\hodor Brainless Giant
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\jon.snow Jon Snow
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\samwell.tarly Samwell Tarly (Password : Heartsbane)
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\jeor.mormont Jeor Mormont
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\sql_svc sql service
(kali@kali)-[~]
└─$
```

Potential Risks:

- Attackers can use valid usernames for brute-force attacks.
- The exposed password increases the risk of privilege escalation.

Mitigation:

- Enforce **password complexity policies**.
- Remove **hardcoded passwords** and/or implement **multi-factor authentication (MFA)**.
- Enable **account lockout policies** to prevent brute-force attacks.

D4. Final Task Execution: Enumerate Guest SMB Access

Command Used:

```
smbclient -L //192.168.56.11 -N
```

Findings:

- **Anonymous login succeeded**, meaning **guest access is enabled**.
- No workgroup was available, and **no shares were listed**, indicating either **strict permissions** or misconfigured SMB settings.
- The connection attempt to 192.168.56.11 failed with `NT_STATUS_RESOURCE_NAME_NOT_FOUND`, suggesting that the SMB share may no longer exist or is restricted.

```
(kali@kali)~$ smbclient -L //192.168.56.11 -N
Anonymous login successful

  Sharename      Type            Comment
  -----
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.11 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

(kali@kali)~$
```

Potential Risks:

- Even though no shares were listed, **allowing anonymous login** can lead to:
 - **Brute-force attacks** against SMB.
 - **Enumeration of system details** via SMB probes.
 - **Potential privilege escalation** if misconfigurations are present.

Mitigation:

- **Disable guest access** for SMB by enforcing authentication.
- **Restrict SMB access** to only **authorized users**.
- **Monitor failed SMB login attempts** to detect reconnaissance activities.
- **Ensure SMBv1 is disabled**, as it is outdated and vulnerable to exploits like **EternalBlue**.